

(small sites). If you try to use Grabber for larger sites, it will take a long time to complete a scan.

w3af

w3af (Web Application Attack and Audit Framework) is popular for auditing attacks on Web applications. This framework deals with the vulnerabilities of Web apps. w3af has been developed using Python. It is relatively simple to use and very extensible. It identifies vulnerabilities in a Web app by sending customised HTTP requests to it. It has been released under the GPLv2.0 licence.

The process with which w3af identifies vulnerabilities is listed below:

- Locates all links, forms and query string parameters
- Sends customised requests to each input and analyses the output
- Generates report with the findings

The simplest way to install w3af in Kali Linux is as follows:

```
apt-get update
apt-get install -y w3af
```

For detailed installation instructions across various platforms, you can refer to <http://docs.w3af.org/en/latest/install.html>.

w3af has three main plugins, which are listed below:

- *Crawl plugin*: To find new URLs and injection points
- *Audit plugin*: To send specially crafted data to the injection points identified by the crawl plugin
- *Attack plugin*: To exploit the vulnerabilities identified by the audit plugin

w3af can be executed in two modes — console mode and GUI mode with the following commands:

```
$ ./w3af_console
w3af >>>

$ ./w3af_gui
```



Figure 1: Web application security tools

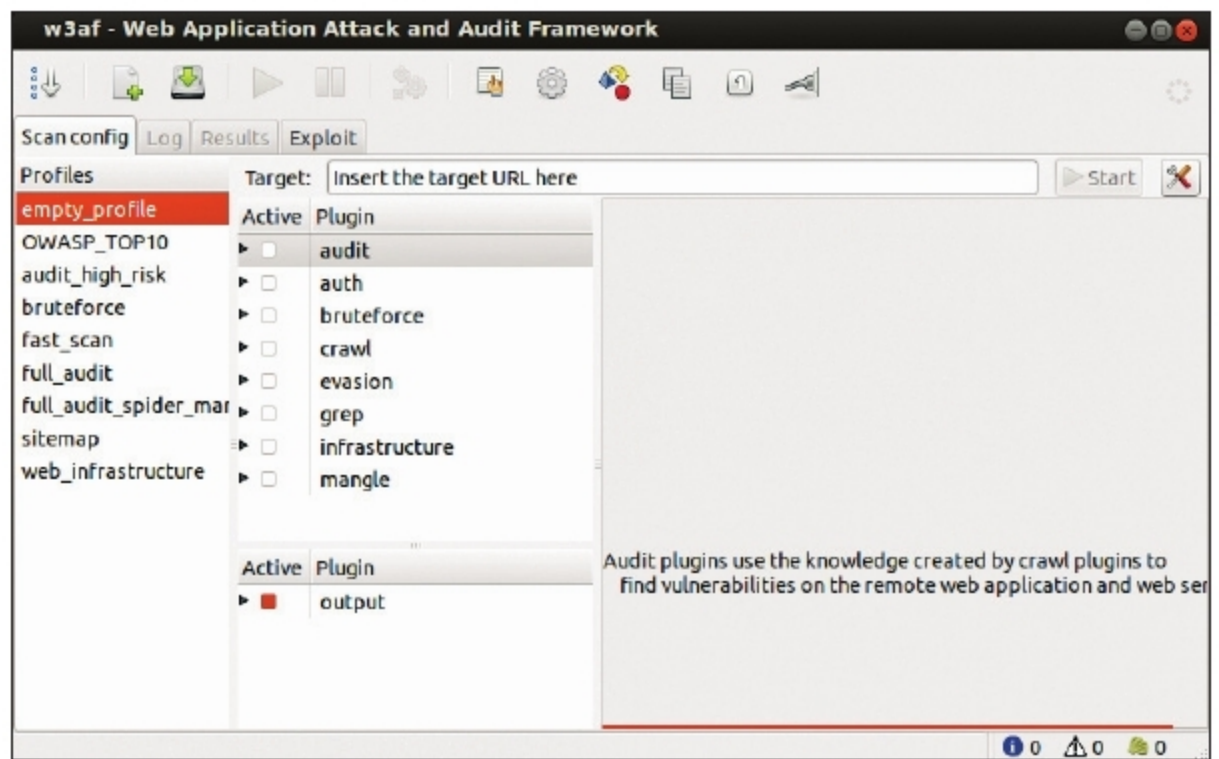


Figure 2: The w3af GUI

Scanning can be started after configuring all the required plugins, as follows:

```
w3af>>> target
w3af/config:target>>> set target http://localhost/
w3af/config:target>>> back
w3af>>>
w3af>>> start
```

As stated earlier, the scanning can be done via the GUI as well. A sample screenshot from the official documentation is shown in Figure 2.

An easy way to get familiar with w3af is to go through the project tour videos provided at the official documentation site (<http://w3af.org/take-a-tour>). A demo to identify and deal with the SQL injection is provided. Detailed documentation on how to use the various features of w3af is provided at <http://docs.w3af.org/en/latest/index.html>.

Zed Attack Proxy (ZAP)

Zed Attack Proxy (ZAP) is a popular, free and open source penetration testing tool. It is maintained by the Open Web Application Security Project (OWASP). The primary objective of ZAP is security testing of Web applications.

ZAP sits in between the browser and the Web application. In this way it can intercept and inspect messages sent between the browser and Web app. It can modify the contents if required. These modified contents can then be forwarded. ZAP can be used as a standalone application or as a daemon process.

ZAP can be installed in all the popular operating systems such as Linux, MacOS and Windows. You can select the appropriate installer from the download section of the official site at <https://www.zaproxy.org/download/>. To run ZAP you require Java version 8+ on your system.

The simplest way to use ZAP is to use the automated scan available under the Quick Start tab, as shown in Figure 3.